Chapter 2. Bedrock 위에서 안전하게 쓰기

키는 나눠 주지 않고, 정책은 파일로, 막을 것은 앞에서 (Claude Code v2.1.319, Bedrock 기준)

Choi, WooHyung

Prin. Solutions Architect

AWS Korea

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

강의 50분, 깊은 내용은 실습에서

세 개의 Part, 연결에서 정책과 가드레일까지

PART 01 / 18분

Bedrock에 연결하기

환경변수 두 개, SSO 로그인, 모델 고정과 팀별 비용

PART 02 / 10분

정책은 파일로

managed settings, 우선순위, /status로 확인

PART 03 / 16분

무엇을 못 하게 할 것인가

deny가 이긴다, 훅은 exit 2, DLP 다섯 겹, 남는 기록

LAB / Ch2 Lab 1

정책 배포, managed settings와 게이트웨이 그룹 정책

정책을 배포하고, 개인 설정으로 우회가 안 되는지 확인

LAB / Ch2 Lab 2

가드레일과 DLP, 훅과 auto mode

훅을 만들고 직접 뚫어 본 뒤 고치기

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

금융권이 Bedrock을 고르는 이유

대신 claude.ai의 관리 콘솔, Analytics, 정책 서버가 없음

01

계정 경계 안의 추론

처리 리전은 추론 프로필 범위를 따름 (global은 리전 밖 처리 가능)

02

기존 통제의 재사용

IAM, IAM Identity Center, CloudTrail, Organizations

03

청구 일원화

AWS 청구서와 Cost Explorer, Budgets로 관리

04

빈자리는 직접 채움

정책은 파일과 MDM으로, 관측은 OTel(OpenTelemetry)로

claude.ai의 관리 콘솔, Analytics, 정책 서버가 없는 자리를 무엇으로 채우는지, 그것이 이 챕터와 Ch6의 이야기입니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

CHAPTER 02 / PART 01

Bedrock에 연결하기

첫 세션까지 가장 짧은 길

01
환경변수 두 개

02
SSO로 로그인

03
모델 고정과 팀별 비용

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

환경변수 두 개면 연결된다

수동 설정과 리전 결정 순서

```
# Bedrock 사용
export CLAUDE_CODE_USE_BEDROCK=1
# 프로필에 리전이 없을 때만 (서울 리전 예시)
export AWS_REGION=ap-northeast-2
# 사내 엔드포인트, 게이트웨이를 쓸 때
# export ANTHROPIC_BEDROCK_BASE_URL=https://...
```

~/.zshrc 또는 settings.json의 env에 둡니다.

이번 세션의 리전

us-east-1

4. 기본값

다음 경우 보기

리전 결정 순서 (위가 먼저). 줄을 눌러 값을 넣고 빼 보세요.
값은 예시입니다.

1	AWS_REGION	ap-northeast-2
2	AWS_DEFAULT_REGION	us-west-2
3	활성 프로필의 region	us-east-1
4	기본값	us-east-1

/status에서 리전이 어디서 왔는지 출처까지 확인합니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

다섯 가지 중 권장은 하나

Bedrock API 키만 AWS SDK 기본 체인을 거치지 않음

AWS CLI 설정	`aws configure`	비권장 (장기 키 디스크 저장)
액세스 키 환경변수	`AWS_ACCESS_KEY_ID` 등	비권장 (장기 키)
SSO 프로필	`aws sso login + AWS_PROFILE`	권장
콘솔 자격증명	`aws login`	보조 수단
Bedrock API 키	`AWS_BEARER_TOKEN_BEDROCK`	비권장 (장기 키)

Bedrock API 키도 장기 키라 **비권장**입니다. 다섯 가지 중 **이 방식만 AWS SDK 기본 자격증명 체인을 거치지 않습니다**. SSO 프로필의 갱신 흐름 대신 키 하나로 인증합니다.

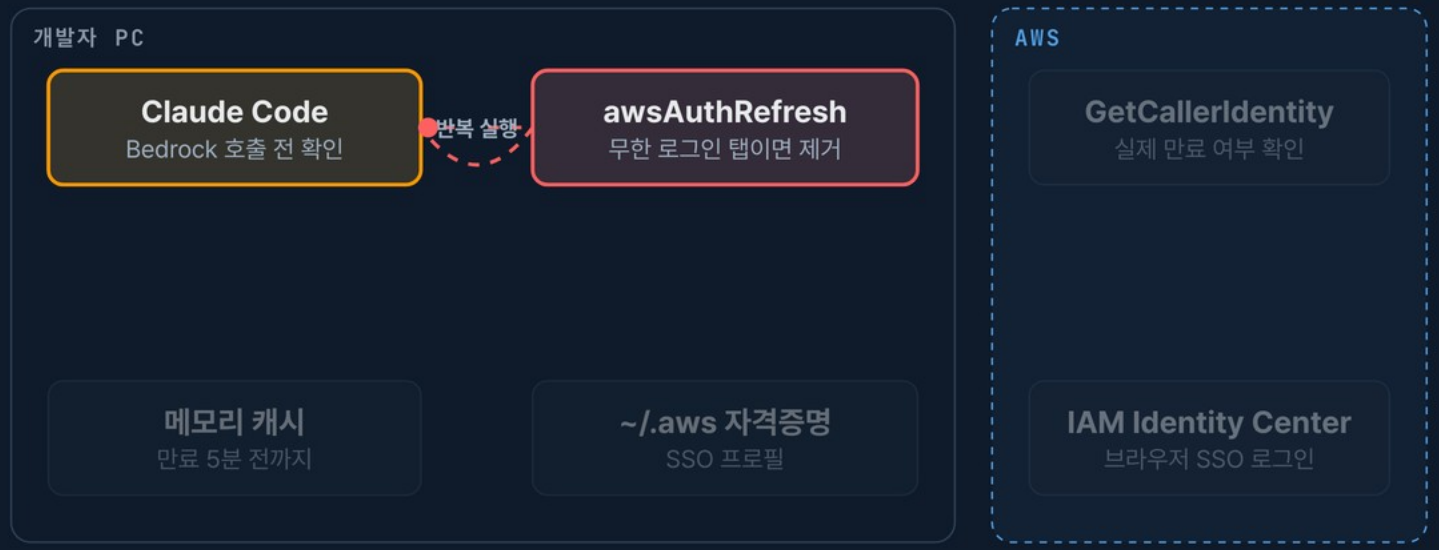
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

만료되면 Claude Code가 대신 로그인한다

SSO 자동 갱신, awsAuthRefresh와 awsCredentialExport

STEP 4 **막힐 때 보는 곳**

프록시와 TLS 검사 환경도 지원합니다. 로그인 탭이 **끝없이 열린다면** **awsAuthRefresh를 제거**하고 원인을 봅니다.



Identity Center와 함께

~/.claude/settings.json 또는 managed (예시)

```
{
  "awsAuthRefresh": "aws sso login --profil
e corp-dev",
  "env": {
    "CLAUDE_CODE_USE_BEDROCK": "1",
    "AWS_PROFILE": "corp-dev",
    "AWS_REGION": "us-east-1"
  }
}
```

Identity Center **권한 세트로 Bedrock 최소 권한**을 줍니다.

- HTTPS_PROXY: 프록시 경유 지원
- TLS 검사 프록시: OS 인증서 저장소 사용
- 무한 로그인 탭: awsAuthRefresh 제거

● Claude Code ● 자격증명 흐름 ● 갱신 명령 ● 문제 상황

‹ 4 / 4 ›

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

고정하지 않으면 무엇이 도는가?

QUICK CHECK, 손을 들어 답해 주세요

모델을 고정하지 않은 Bedrock 배포에서 기본 주 모델은?

A Sonnet 4.5

B Opus 5.5

C Haiku 5.5

D Sonnet 5.5

정답 B. 고정하지 않으면 Opus 단가로 청구됩니다. (amazon-bedrock 문서)

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

여러 사용자에게 배포하면 반드시 고정

ANTHROPIC_DEFAULT_*와 리전에 따른 prefix 규칙

```
# managed settings env, 이 랩: us-east-1, global 프로필
ANTHROPIC_DEFAULT_OPUS_MODEL=global.anthropic.claude-opus-5-5
ANTHROPIC_DEFAULT_SONNET_MODEL=global.anthropic.claude-sonnet-5-5
ANTHROPIC_DEFAULT_HAIKU_MODEL=global.anthropic.claude-haiku-5-5

# 고정 대신 prefix만 바꾸기
ANTHROPIC_BEDROCK_REGION_PREFIX=global
```

허용값: us, eu, apac, jp, au, global. 계정에 있는 profile ID로 채웁니다.

리전을 고르면 prefix가 바뀝니다.

us-* → **us.**	eu-* → **eu.**
ap-* (서울 포함) → **apac.**	그 외 → **global.**

그 밖의 리전은 **global.** 프로필을 씁니다.

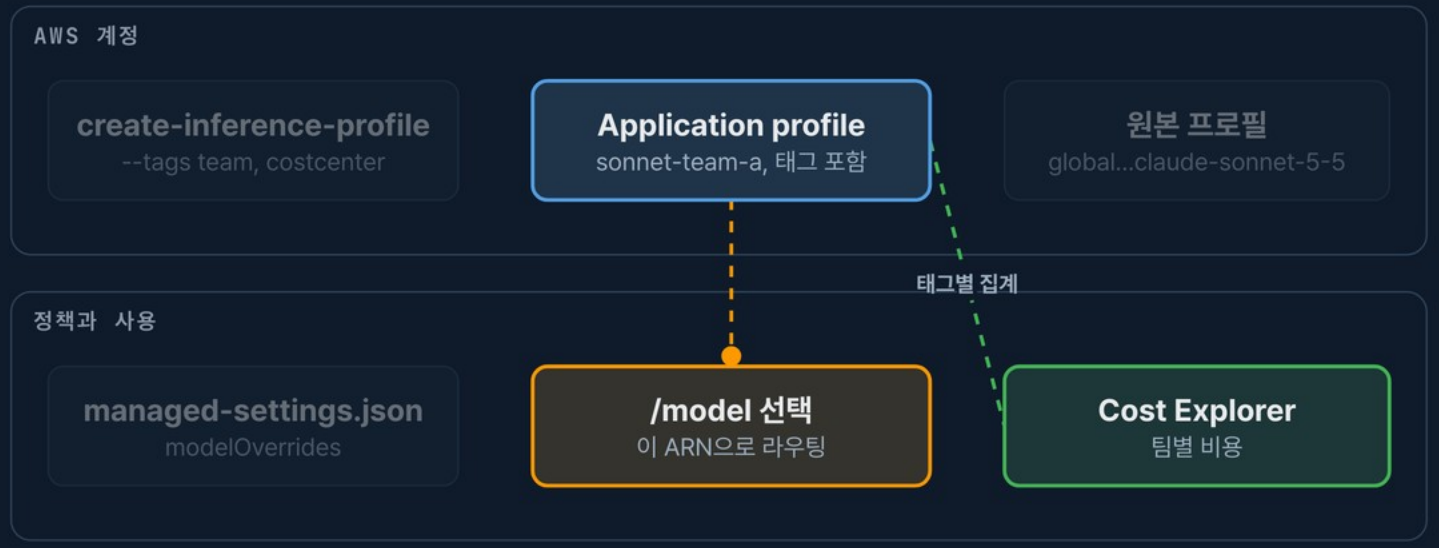
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

팀별 비용은 프로필 ARN이 가른다

Application inference profile로 경로와 비용 경계를 고정

STEP 3 **태그가 Cost Explorer에서 팀을 가릅니다**

프로필의 태그로 **Cost Explorer에서 팀별 비용**을 봅니다. 단, 태그는 **Billing에서 비용 할당 태그로 활성화**해야 보입니다.



놓치기 쉬운 것

Billing

```
# 태그는 만든다고 바로 보이지 않음
비용 할당 태그로 활성화
  team
  costcenter
```

활성화하지 않으면 Cost Explorer에서 **팀별로 나뉘지 않습니다**.

- Billing에서 비용 할당 태그 활성화
- 팀마다 프로필 하나 = 비용, 쿼터, 로그 경계
- IAM에서 프로필 ARN 단위로 허용 가능

● 만들기 ● 프로필 ● 정책과 선택 ● 비용 보기

‹ 3 / 3 ›

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

CHAPTER 02 / PART 02

정책은 파일로

콘솔이 없으니 파일이 정책이다

01
managed settings 파일

02
같은 키는 위가 이긴다

03
/status로 확인

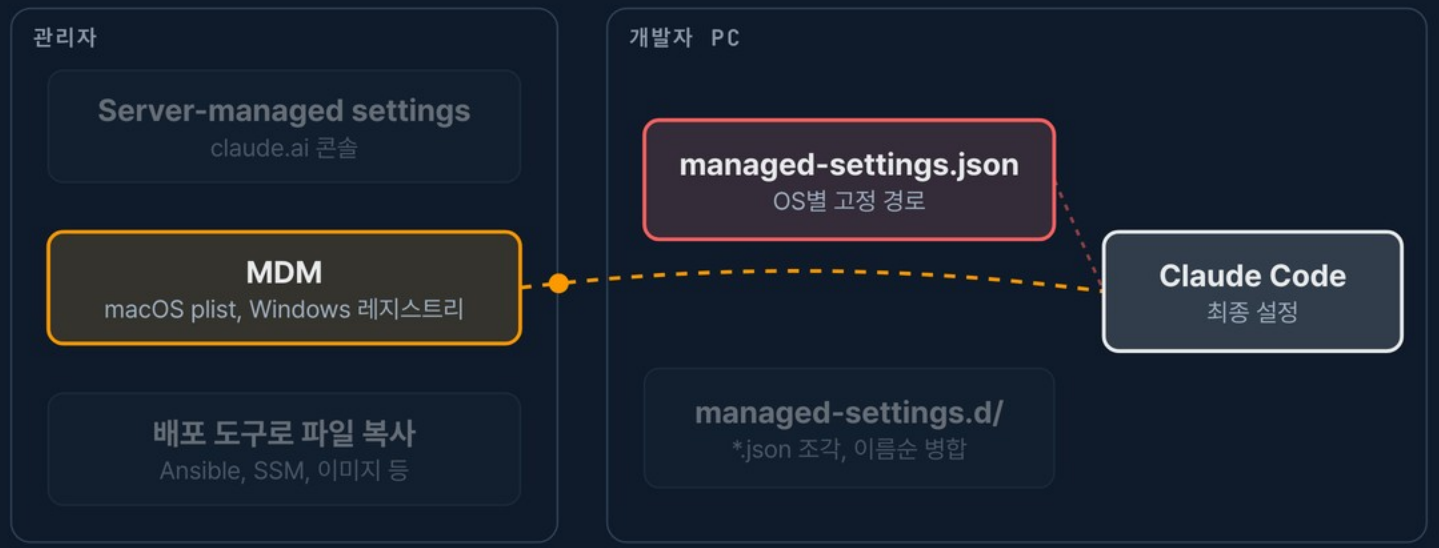
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

콘솔 대신 파일과 MDM으로 닿는다

Bedrock에서 정책이 도달하는 길과 병합 규칙

ONE SOURCE **기본은 한 소스만, merge로 합침**

managed 소스가 여럿이면 기본은 **서버, MDM, 파일 순으로 먼저 정책을 주는 소스 하나만** 적용합니다. **managedSourcesBehavior를 "merge"**로 두면 모두 합칩니다.



● 배포 채널 ● 사용자가 못 바꾸는 파일 ● 적용 결과 ● Bedrock에서 쓸 수 없음

병합 동작

managed settings

```
# 기본: 한 소스만 (서버, MDM, 파일 순)

"managedSourcesBehavior": "merge"
# 모든 managed 소스를 합침
```

팀별 조각은 managed-settings.d/ drop-in으로 나눕니다.

- 기본: 먼저 정책을 주는 소스 하나
- 순서: 서버, MDM, 파일
- "merge": 모든 managed 소스 합침

‹ 6 / 6 ›

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

같은 키가 충돌하면 위가 이긴다

설정 우선순위 다섯 층, 값을 넣어 보며 확인

1	Managed	파일, MDM. 사용자가 덮어쓸 수 없음 managed-settings.json	sonnet
2	CLI 인자	이번 세션에만 적용 --settings	haiku
3	Local	개인, 커밋하지 않음 .claude/settings.local.json	opus
4	Project	팀 공유, 저장소에 커밋 .claude/settings.json	sonnet
5	**User**	내 PC의 모든 프로젝트 ~/.claude/settings.json	**opus**

이번 세션의 모델 (예시 키)

opus

5. User가 이김

다음 경우 보기

줄을 눌러 그 층에 값을 넣고 빼 보세요. 오른쪽 값은 설명용 예시입니다.

개인 설정만 남으면 User 값이 쓰입니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

배포했다고 끝이 아니다

적용 검증 4단계

1

/status 확인

Setting sources에 Enterprise managed settings가 보이는지

2

덮어쓰기 실패 확인

~/.claude/settings.json에서 같은 키를 바꿔도 적용되지 않는지

3

모델 선택 확인

/model에 허용한 모델만 보이는지

4

차단 규칙 확인

.env 읽기를 요청했을 때 거부되는지

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

CHAPTER 02 / PART 03

무엇을 못 하게 할 것인가

앞에서 막고, 못 막은 것은 기록으로

01
deny가 항상 이긴다

02
훅은 exit 2만 차단

03
DLP 다섯 겹과 남는 기록

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

138명 중 51명이 고른 주제

사전 설문, 망분리와 보안(DLP, 감사로그)에 대한 기대

PRE-SURVEY

51

참가 확정자 **138명 중 51명**이 "망분리, 보안(DLP, 감사로그)"를 기대 주제로 골랐습니다.

이 챕터는 그 기대에 답하는 시간입니다. 무엇을 막을 수 있고, 무엇이 기록으로 남는지 정리합니다.



복수 선택 응답, 막대 길이는 응답 인원

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

deny가 항상 이긴다

권한 평가 순서와 Tool(specifier) 규칙 문법

STEP 5 **4 일치 없음: 모드가 정합니다**

어느 규칙에도 일치하지 않으면 **현재 권한 모드의 기본 동작**을 따릅니다. 복잡한 판단은 규칙 대신 **훅**으로 넘깁니다.



현장에서 걸리는 지점

```
# Bash 패턴은 우회가 쉬움: 샌드박스와 함께
# 경로는 ./ 기준 상대 경로
# MCP는 mcp__서버명 단위
# 복잡한 판단은 훅으로
```

규칙은 **문법**이고, 강제력은 다음 장의 **잠금 키**에서 나옵니다.

- default면 확인, acceptEdits면 편집 자동 등
- 모드는 Ch1에서 본 Shift+Tab
- 복잡한 판단은 훅 (이 Part 뒤쪽)

● 거부 ● 사람 확인 ● 바로 실행 ● 다음 단계로

‹ 5 / 5 ›

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

user allow, managed deny라면?

QUICK CHECK, 손을 들어 답해 주세요

user settings에 allow "Bash(curl *)", managed에 deny "Bash(curl *)". 결과는?

A 그대로 실행

B 확인 후 실행

C 거부

D 나중 설정이 이김

정답 C. 권한 규칙은 합쳐지고, deny가 먼저 평가됩니다.

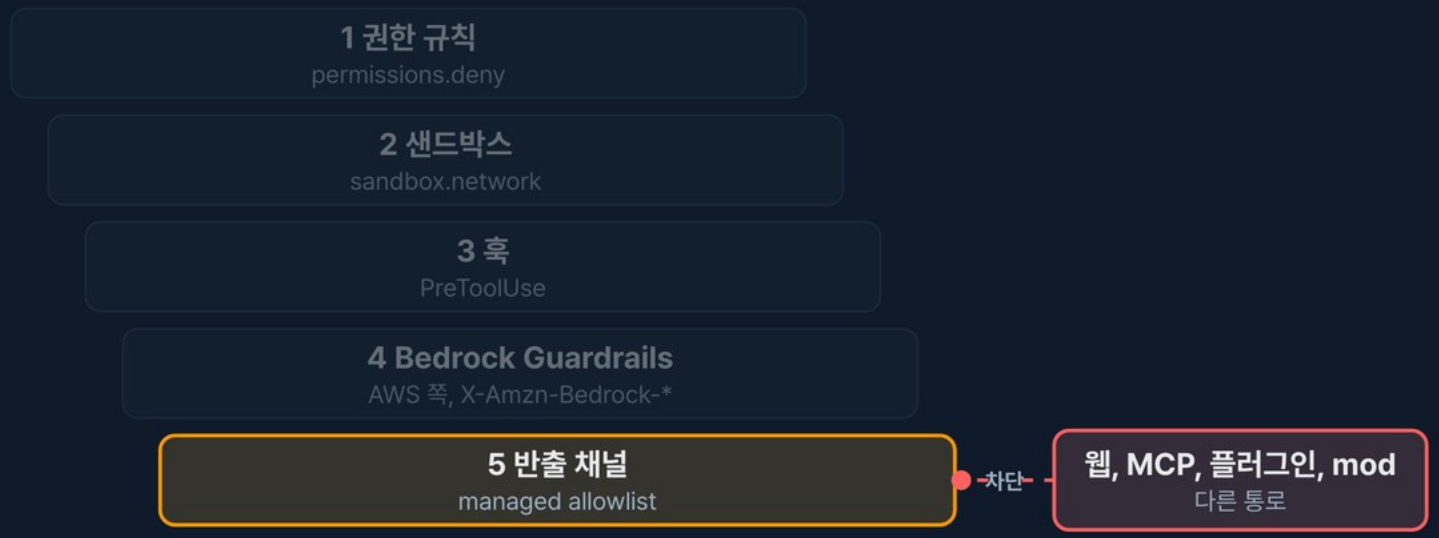
aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

각 층은 앞 층이 놓친 것을 잡는다

DLP 5층과 층마다의 설정

LAYER 5 **반출 채널: 다른 통로를 닫습니다**

웹, MCP, 플러러그인, mod처럼 **데이터가 나갈 수 있는 다른 통로**를 허용 목록으로 닫습니다.



통로별 장치

managed allowlist

```
# 웹
WebFetch: deny 또는 domain: 규칙
skipWebFetchPreflight  # 사전 검사 끔
# MCP
allowedMcpServers
allowManagedMcpServersOnly
# 플러그인, mod
마켓플레이스 허용 목록, 사이드로드 금지
```

MCP 서버 하나, 플러그인 하나가 **새 통로 하나**입니다.

- 웹: Bedrock은 내장 WebSearch 없음, WebFetch는 deny 또는 domain: 규칙, 검색 MCP도 허용 목록
- WebFetch 사전 검사가 호스트명을 Anthropic으로 보냄, skipWebFetchPreflight로 끔
- MCP: allowedMcpServers, allowManagedMcpServersOnly
- 플러그인, mod: 마켓플레이스 허용 목록, 사이드로드 금지, 사용자 mod 차단

● PC 쪽 층 ● AWS 쪽 층 ● 그 층이 막는 것 ● 앞 층이 놓친 것

‹ 6 / 6 ›

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

exit 2만 차단이다

3층 DLP 훅 예제와 fail-open, 그리고 수정본

CASE 4 **수정본은 오류 경로도 막습니다**

수정본은 jq 해석이 실패하면 **exit 2**로 막고, grep 결과가 **1(불일치)일 때만** 통과시킵니다. 0(일치)과 2 이상(실행 오류)은 모두 차단합니다. 이것이 **fail-closed**입니다.



입력 통과 차단 검사 실패

/opt/dlp/dlp-guard.sh

수정본 (fail-closed)

```
#!/bin/bash
INPUT=$(cat)
TEXT=$(echo "$INPUT" | jq -r '.prompt // (.tool_input | tostring)') \
  || { echo "DLP: 입력 해석 실패 - 차단" >&2; exit 2; }
PAT='[0-9]{6}-[1-4][0-9]{6}|[0-9]{4}-[0-9]{4}-[0-9]{4}-[0-9]{4}|AKIA[0-9A-Z]{16}'
echo "$TEXT" | grep -Eq "$PAT"; RC=$?
[ "$RC" -eq 1 ] && exit 0   # 1 불일치, 통과
echo "DLP: 차단(grep $RC: 0 일치, 2+ 실행 오류)" >&2; exit 2
```

다음 장에서 이 수정본을 **정책으로 강제**합니다.

- jq 해석 실패: exit 2로 차단
- grep 1(불일치)만 통과
- 0 일치, 2+ 실행 오류는 차단

‹ 4 / 4 ›

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

jq 없이 exit 127이면?

QUICK CHECK, 손을 들어 답해 주세요

DLP 훅이 jq 미설치로 exit 127로 끝나면 어떻게 될까요?

A 차단된다

B 통과된다

C 세션이 종료된다

D 자동 재시도

정답 B. exit 2만 차단입니다. 그 외 0이 아닌 종료는 비차단 오류로 처리되어 그대로 진행됩니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

감사에 답할 근거는 네 곳에 남는다

무엇이 기록으로 남는가, 그리고 주의할 것

남는 것

- PC: 세션 JSONL
  cleanupPeriodDays로 보존 기간
- AWS: CloudTrail의 Bedrock 호출 이력
- AWS: Bedrock model invocation logging
  선택, 프롬프트 원문 포함
- OTel: 사용자별 토큰, 비용, 도구
  Ch6

주의할 것

- invocation logging은 원문이 저장되므로 저장소, 보존 정책 필요
- Anthropic으로 가는 텔레메트리는 Bedrock에서 기본 꺼짐
  단, WebFetch 사전 검사는 호스트명을 api.anthropic.com으로 보냄 (skipWebFetchPreflight로 끔)
- ZDR은 AWS 계약 조건에 따름
- 세션 로그도 고객 데이터를 담을 수 있음

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

더 깊은 내용은 실습에서 손으로

강의에서 줄인 주제와 실습 TASK

Lab 1 TASK 01	지금의 연결 읽기: env, 추론 프로필, 최소 IAM 정책과 비교	IAM 세부
Lab 1 TASK 02부터 04	정책 배포, 개인 설정으로 우회 시도, 정책 파일이 깨지면?	정책 배포
Lab 1 TASK 06	같은 정책을 게이트웨이 그룹 정책으로 내려보내기	게이트웨이
Lab 2 TASK 01, 02	DLP 훅을 정책으로 강제하고, fail-open을 고치기	훅
Lab 2 TASK 03	auto mode로 확인 창을 줄이고 경계 긋기	auto mode
Lab 2 선택 TASK	샌드박스로 curl 빈틈 막기, Bedrock Guardrails, 확장 통제	DLP 층

망분리 준비물, OS별 차이, 쿼터는 PDF 강의자료(정책편, 가드레일편)의 더 알아보기에 있습니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

기억할 여섯 줄

Chapter 2 Key Takeaways

01

CLAUDE_CODE_USE_BEDROCK + 리전이면 연결 완료

02

장기 키 대신 SSO 프로필 + awsAuthRefresh

03

모델은 반드시 고정, 팀별 비용은 프로필 ARN으로

04

정책은 managed-settings.json, 충돌하면 managed가 이기고 /status로 확인

05

권한은 deny가 먼저, 훅은 exit 2만 차단하니 오류 경로도 exit 2로

06

네이티브 DLP는 없다, 다섯 겹을 쌓고 못 막은 것은 기록으로

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Thank You

다음은 점심입니다. 13:00 통합 랩에서 Preflight와 Ch1 Lab을 마친 뒤, 오늘 본 정책과 훅을 Ch2 Lab 1, Lab 2에서 직접 배포하고 뚫어 봅니다. 질문은 Slack #20261116-claude-code-workshop-for-fsi 채널에서 언제든 받습니다.

← 목차로 돌아가기 Chapter 3 (14:00) →

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.